Estratégia Concursos

# Aula 38

*DataPrev (Analista de TI - Desenvolvimento de Software) Passo Estratégico de Conhecimentos Específicos - 2024 (Pós-Edital)*

Autor:

09 de Setembro de 2024

11225354498 - Maria Vitória Gonçalves Vieira

# Segurança de Redes

Sumário


Conteúdo 2
Glossário de termos 3
Roteiro de revisão 5
Introdução e Conceitos Básicos 5
Tipos de Ameaças e Ataques 6
Antivírus 9
Firewall 13
Proxy 17
IDS e IPS 18
EDR 22
VPN 23
NAT 26
**Aposta estratégica** **29**
Questões Estratégicas 30
Questionário de revisão e aperfeiçoamento 33
Perguntas 34
Perguntas e Respostas 35
Lista de Questões Estratégicas 37
Gabaritos 39


## Conteúdo

Segurança em Redes. Malwares. Antimalwares: antivírus, firewall, IDS, IPS. EDR. NAT. VPN

## Análise Estatística

Inicialmente, convém destacar o percentual de incidência do assunto, dentro da disciplina **Segurança da Informação** em concursos/cargos similares. Quanto maior o percentual de cobrança de um dado assunto, maior sua importância.



11225354498 - Maria Vitória Gonçalves Vieira

Obs.: *um mesmo assunto pode ser classificado em mais de um tópico devido à multidisciplinaridade de conteúdo.*

| Assunto | Relevância na disciplina em concursos similares |
|---|---|
| Criptografia | **11.4 %** |
| Análise de Vulnerabilidade e Gestão de Riscos | **11.4 %** |
| Plano de Continuidade de Negócios | **8.6 %** |
| Norma 27005 | **8.6 %** |
| Backup em Segurança da Informação | **5.7 %** |
| Conceitos Básicos em Segurança da Informação | **5.7 %** |
| Políticas de Segurança de Informação | **5.7 %** |
| Norma ISO 27001/27002 | **5.7 %** |
| Certificação Digital em Segurança da Informação | **5.7 %** |
| Ataques e ameaças | **5.7 %** |
| Planos de contingência | **2.9 %** |
| Sistemas de Prevenção-Detecção de Intrusão | **2.9 %** |
| 1. IDS (Intrusion Detection System) | **2.9 %** |
| 2. IPS (Intrusion Prevention System) | **2.9 %** |
| Segurança de sistemas de informação | **2.9 %** |
| Infraestrutura de Chaves Públicas (PKI) | **2.9 %** |
| Controles de segurança | **2.9 %** |
| Assinatura Digital | **2.9 %** |
| Malware | **2.9 %** |



11225354498 - Maria Vitória Gonçalves Vieira

# GLOSSÁRIO DE TERMOS

*Faremos uma lista de termos que são relevantes ao entendimento do assunto desta aula. Caso tenha alguma dúvida durante a leitura, esta seção pode lhe ajudar a esclarecer.*

1. Malware: Software projetado para danificar, interromper ou obter acesso não autorizado a sistemas de computador.

2. Vírus: Um tipo de malware que, quando executado, se replica ao modificar outros programas de computador e inserir seu próprio código.

3. Worm: Um tipo de malware que se propaga sem a necessidade de interação humana.

4. Trojan: Um tipo de malware que se disfarça como um programa legítimo, enganando o usuário para instalar um programa malicioso.

5. Ransomware: Um tipo de malware que criptografa os dados do usuário e exige um resgate para restaurar o acesso aos dados.

6. Spyware: Um tipo de malware que coleta informações sobre os usuários sem o seu consentimento.

7. Phishing: Técnica de fraude online onde um atacante tenta enganar o usuário para que revele informações pessoais.

8. DoS/DDoS: Ataque de negação de serviço/ataque de negação de serviço distribuído. Um ataque que tem como objetivo tornar um recurso de computador ou rede indisponível.

9. Ataque de Força Bruta: Método de tentativa e erro usado para descobrir informações sensíveis, como senhas.

10. Ataque de Interceptação e Espionagem: Ataque no qual a comunicação entre duas entidades é intencionalmente interceptada e potencialmente alterada.

11. Antivírus: Software usado para prevenir, detectar e remover malware.

12. Antispam: Ferramentas e técnicas usadas para detectar e bloquear mensagens de spam.



11225354498 - Maria Vitória Gonçalves Vieira

13. Antispyware: Software projetado para detectar, prevenir e remover spyware.

14. Firewall: Sistema de segurança de rede que monitora e controla o tráfego de dados com base em regras de segurança predefinidas.

15. Proxy: Servidor que age como intermediário para solicitações de recursos por parte de clientes.

16. IDS (Sistema de Detecção de Intrusões): Dispositivo ou aplicativo que monitora a rede para identificar atividades potencialmente prejudiciais.

17. IPS (Sistema de Prevenção de Intrusões): Solução de segurança que funciona para detectar e prevenir ameaças identificadas pelo IDS.

18. Honeypot: Recurso de rede projetado para atrair e distrair invasores, permitindo que os sistemas de segurança identifiquem e estudem as atividades dos invasores.

19. EDR (Endpoint Detection and Response): Solução de segurança que reúne e analisa dados de eventos de endpoints para detectar ameaças, investigar incidentes e responder adequadamente.

20. VPN (Virtual Private Network): Tecnologia que cria uma conexão de rede segura sobre uma rede pública, protegendo os dados à medida que são transmitidos.

21. NAT (Network Address Translation): Processo que traduz os endereços IP de uma rede para outra, geralmente de uma rede privada para uma rede pública.

## Roteiro de revisão

*A ideia desta seção é apresentar um roteiro para que você realize uma revisão completa do assunto e, ao mesmo tempo, destacar aspectos do conteúdo que merecem atenção.*



11225354498 - Maria Vitória Gonçalves Vieira

# Introdução e Conceitos Básicos

Segurança de redes é o conjunto de medidas adotadas para proteger a infraestrutura de rede contra diferentes tipos de ameaças, ataques ou acessos não autorizados. Ela inclui políticas, procedimentos e tecnologias que visam a garantir a confidencialidade, integridade e disponibilidade dos dados em uma rede.

Este tipo de segurança é crucial por várias razões:

- Confidencialidade: Para proteger informações sensíveis de serem acessadas por partes não autorizadas. Isso é especialmente crítico para empresas que lidam com dados pessoais, informações financeiras ou propriedade intelectual.
- Integridade: Para garantir que os dados não sejam alterados durante o trânsito ou em repouso. A integridade dos dados é essencial para manter a precisão e a consistência dos dados ao longo de seu ciclo de vida.
- Disponibilidade: Para garantir que os recursos da rede estejam disponíveis para uso legítimo sempre que necessário. Interrupções ou tempo de inatividade podem ter um impacto negativo significativo nas operações de negócios.
- Conformidade Legal: Diversas regulamentações exigem que as organizações protejam dados pessoais e outros tipos de informações.

Antes que adentrarmos em conceitos mais específicos, vamos revisar algumas definições básicas e conceitos fundamentais que serão importantes nesta aula:

- Política de Segurança: É um documento que delineia as regras, diretrizes e procedimentos que uma organização deve seguir para proteger seus ativos de rede.
- Controle de Acesso: Refere-se aos mecanismos que restringem o acesso a recursos de rede com base em usuários, grupos, funções e outras políticas.
- Criptografia: É a técnica de codificar dados para proteger sua confidencialidade. É fundamental para proteger dados durante a transmissão e em repouso.
- Firewall: Uma barreira de segurança que monitora e controla o tráfego de rede com base em regras de segurança predefinidas.
- Antivírus: Software projetado para detectar e neutralizar malware, como vírus, worms, trojans, ransomware, etc.
- VPN (Virtual Private Network): Uma tecnologia que cria uma conexão segura e criptografada sobre uma rede menos segura, como a Internet.
- IDS/IPS (Sistemas de Detecção e Prevenção de Intrusão): Ferramentas de segurança que monitoram a rede e/ou os sistemas em busca de atividades maliciosas ou violações de políticas.



11225354498 - Maria Vitória Gonçalves Vieira

- Segurança Física: Proteção de hardware, software, redes e dados contra danos físicos, roubo e interrupção de serviço devido a desastres naturais ou humanos.

Cada um desses conceitos será abordado em maiores detalhes nas próximas seções.

## Tipos de Ameaças e Ataques

Existem diversos tipos ameaças e ataques que exploram vulnerabilidades em redes de computadores. Vamos revisar os mais comuns.

### Malware

Malware é um termo genérico para qualquer tipo de software malicioso projetado para prejudicar ou explorar qualquer dispositivo de computação ou rede. Inclui vírus, worms, trojans, ransomware, spyware, adware, entre outros. Alguns exemplos são:

- Vírus: Um tipo de malware que se replica e se espalha para outros sistemas, geralmente acoplado a um arquivo executável.
- Worms: Semelhante a um vírus, mas pode se propagar sem a necessidade de anexar-se a um programa ou arquivo existente.
- Trojans: Malware que se disfarça como um software legítimo ou está incorporado em software legítimo que foi adulterado.
- Ransomware: Um tipo de malware que criptografa os dados do usuário e exige pagamento para desbloqueá-los.
- Spyware: Software que coleta informações sobre um usuário ou organização sem o seu conhecimento

### Phishing

Phishing é uma técnica de engenharia social usada para enganar os usuários e obter informações confidenciais, como nomes de usuário, senhas e detalhes do cartão de crédito, geralmente por meio de e-mails ou sites falsos.




Por exemplo, uma pessoa recebe um e-mail que parece ser de seu banco, informando-a de que sua conta será suspensa se ela não clicar em um link e atualizar suas informações de segurança. O e-mail parece legítimo, com o mesmo logotipo e formato que o banco normalmente usa. No entanto, ao clicar no link, a pessoa é levada para um site falso que se parece com o site do banco, mas na verdade é uma tentativa de obter suas credenciais de login.

## Dos/DDoS

DoS (Denial of Service) e DDoS (Distributed Denial of Service) são ataques destinados a tornar um sistema ou rede indisponível para seus usuários pretendidos. Isso é feito inundando o sistema ou rede com tráfego inútil ou solicitações para sobrecarregá-lo.







Por exemplo, imagine que você tem um site de comércio eletrônico. Um dia, você descobre que seu site está inacessível. Após uma investigação, descobre que um atacante está inundando seu servidor com tráfego inútil, sobrecarregando seus recursos e tornando o site inacessível para seus clientes legítimos. Isso é um exemplo de um ataque de negação de serviço (DoS). Caso esse ataque venha de diversos

lugares distribuídos geograficamente, damos o nome de DDoS, que nada mais é do que um DoS distribuído.

### Ataques de Força Bruta

Um ataque de força bruta tenta adivinhar as credenciais de um usuário (como nome de usuário e senha) tentando todas as combinações possíveis até encontrar a correta. Este tipo de ataque pode ser muito eficaz se as senhas forem fracas ou comuns.

Por exemplo, uma pessoa usa a mesma senha simples para todos os seus logins online. Um dia, um hacker decide tentar acessar sua conta de e-mail. O hacker usa um programa de força bruta que sistematicamente testa todas as possíveis combinações de senhas até que finalmente acerta a senha da pessoa. Agora, o hacker tem acesso total à conta de e-mail deste indivíduo.

### Ataques de interceptação e espionagem

Esses ataques envolvem a captura não autorizada de dados durante a transmissão. Isso pode ser feito através de métodos como *eavesdropping*, onde um invasor 'escuta' as comunicações de rede, ou man-in-the-middle (MitM), onde o invasor se insere entre duas partes que estão se comunicando e intercepta ou altera a comunicação.

Por exemplo, uma pessoa está em um café e se conecta à rede Wi-Fi gratuita disponível. Ela não percebe que um invasor está na mesma rede, usando uma técnica chamada "sniffing" para interceptar o tráfego de rede. Quando a pessoa faz login em sua conta bancária online, o invasor capta suas credenciais de login. Agora, o invasor tem acesso à conta bancária desta pessoa e, possivelmente, outras informações.

## Antivírus

Antivírus é um tipo de software de segurança projetado para proteger computadores e redes contra software malicioso, mais comumente conhecido como "malware". Isso inclui vírus, worms, trojans, ransomware, spyware, adware e outros tipos de software prejudiciais.

Antivírus funcionam de várias maneiras para proteger um sistema, dentre as quais podemos citar:

- Varredura de arquivos: O antivírus verifica todos os arquivos do sistema em busca de código conhecido como malicioso. Isso geralmente é feito comparando os arquivos a uma biblioteca de assinaturas de vírus conhecidos.
- Monitoramento em tempo real: Além de varrer arquivos existentes, muitos programas antivírus também monitoram constantemente a atividade do sistema para detectar comportamentos suspeitos que podem indicar a presença de malware.
- Quarentena e remoção: Quando o antivírus detecta um arquivo suspeito, ele pode colocar o arquivo em quarentena, o que impede que ele cause danos ao sistema, ou tentar removê-lo completamente.
- Proteção contra ataques online: Alguns programas antivírus também incluem recursos para proteger contra ameaças online, como downloads perigosos, links de phishing e sites perigosos.
- Atualizações regulares: Como novos tipos de malware estão sempre sendo criados, os programas antivírus precisam ser atualizados regularmente para que possam reconhecer e proteger contra as ameaças mais recentes.

## Tipos de Antivírus

Podemos dividir antivírus em 4 gerações distintas, de acordo com o seu tipo de funcionamento e suas capacidades.

### 1ª Geração: Detecção baseada em Assinatura

Nesta geração, os antivírus operavam principalmente através da detecção de assinaturas. Eles procuravam por códigos conhecidos como maliciosos em programas e arquivos. Esses códigos, ou "assinaturas", eram coletados em um banco de dados mantido pelo fornecedor do antivírus. Quando um arquivo com uma assinatura correspondente era encontrado, o antivírus sinalizava como potencialmente malicioso. Embora eficaz contra ameaças conhecidas, essa abordagem tinha a limitação de não poder detectar malware novo ou modificado que ainda não tivesse uma assinatura conhecida.

### 2ª Geração: Detecção baseada em Heurística

Para lidar com a limitação de apenas poder detectar malware conhecido, a detecção baseada em heurística foi introduzida. Em vez de procurar por assinaturas específicas, os antivírus heurísticos procuram por comportamentos ou características suspeitas que



11225354498 - Maria Vitória Gonçalves Vieira

possam indicar a presença de malware. Isso inclui coisas como tentativas de modificar certos arquivos de sistema, ou um programa tentando se conectar a um endereço IP suspeito. Essa abordagem pode ser mais capaz de detectar novas ameaças, mas também pode levar a mais falsos positivos.

3ª Geração: Interceptação de Atividade

Os antivírus de terceira geração adicionaram a capacidade de monitorar e interceptar atividades potencialmente maliciosas em tempo real. Em vez de apenas verificar arquivos em busca de malware, esses antivírus poderiam monitorar o comportamento dos programas em execução no sistema. Se um programa começasse a agir de maneira suspeita, o antivírus poderia bloquear suas ações antes que causasse danos. Isso deu aos antivírus a capacidade de lidar melhor com ameaças desconhecidas ou mutáveis.

4ª Geração: Proteção Completa

Os antivírus de quarta geração, também conhecidos como soluções de "proteção completa" ou "endpoint", oferecem uma gama ainda mais ampla de recursos de segurança. Além das capacidades das gerações anteriores, eles podem incluir coisas como firewalls integrados, proteção contra phishing, controle de aplicativos, proteção contra explorações, e até mesmo capacidades de aprendizado de máquina para melhorar a detecção de ameaças. Eles também podem incluir recursos para proteger contra ameaças não tradicionais, como ransomware e ataques de dia zero.

A tabela a seguir comparando as gerações de antivírus:

| | 1ª Geração: Detecção Baseada em Assinatura | 2ª Geração: Detecção Baseada em Heurística | 3ª Geração: Interceptação de Atividade | 4ª Geração: Proteção Completa |
|---|---|---|---|---|
| **Definição** | **Baseia-se na detecção de assinaturas de vírus conhecidos em um sistema.** | **Usa algoritmos para analisar o comportamento de um programa e determinar se é malicioso.** | **Monitora a atividade do sistema para detectar comportamento anormal ou malicioso.** | **Combina várias técnicas de detecção, além de oferecer recursos adicionais de proteção.** |



11225354498 - Maria Vitória Gonçalves Vieira

| | | | | |
|---|---|---|---|---|
| **Como funciona** | **Verifica os arquivos contra um banco de dados de assinaturas de vírus.** | **Analisa o código de um programa para identificar padrões suspeitos de comportamento.** | **Monitora o sistema e identifica comportamentos maliciosos com base em regras ou modelos de aprendizado de máquina.** | **Combina métodos de detecção baseados em assinatura, heurística e interceptação de atividade, além de outros recursos de segurança.** |
| **Exemplos** | **McAfee VirusScan, Norton Antivirus** | **Eset NOD32, Avast** | **Norton Antivirus com Sonar, Trend Micro** | **Sophos Intercept X, Norton 360** |
| **Vantagens** | **Eficaz contra malwares conhecidos.** | **Pode detectar novas variantes de malware que não foram identificadas ainda.** | **Pode identificar atividades maliciosas sem a necessidade de uma assinatura específica.** | **Oferece proteção abrangente contra uma ampla variedade de ameaças.** |
| **Desvantagens** | **Ineficaz contra malwares novos ou modificados.** | **Pode gerar falsos positivos.** | **Pode não ser eficaz contra malware altamente sofisticado ou ataques de dia zero.** | **Pode ser mais pesado em termos de uso de recursos do sistema.** |

## Antispam e Antispyware

Duas ferramentas que costumam vir "empacotadas" em muitos antivírus são as ferramentas de Antispam e Antispyware.

AntiSpam



11225354498 - Maria Vitória Gonçalves Vieira

Antispam é um tipo de software que é usado para detectar, prevenir e remover mensagens de spam. Spam se refere a mensagens eletrônicas não solicitadas, frequentemente enviadas em massa, geralmente por e-mail, mas também através de outros meios de comunicação, como mensagens de texto, mensagens instantâneas e postagens em redes sociais.

Os filtros de spam usam uma várias técnicas para identificar e bloquear mensagens de spam, incluindo:

- Listas negras de IP: Estas são listas de endereços IP conhecidos por enviar spam. Qualquer mensagem proveniente desses IPs pode ser automaticamente marcada como spam.
- Filtros de conteúdo: Estes filtros analisam o conteúdo das mensagens para procurar palavras-chave, frases ou padrões comuns em mensagens de spam.
- Filtros baseados em reputação: Estes filtros usam informações sobre o remetente, como se eles estão em uma lista negra ou se eles têm um histórico de envio de spam, para determinar se uma mensagem é spam.
- Filtros heurísticos: Esses filtros procuram por comportamentos ou características suspeitas que podem indicar spam, mesmo que a mensagem não corresponda a nenhuma assinatura de spam conhecida.

Antispyware

Antispyware é um tipo de software de segurança projetado para detectar, prevenir e remover spyware. Spyware é um tipo de malware que se instala em um computador ou dispositivo móvel sem o conhecimento ou consentimento do usuário e coleta informações sobre eles sem o seu conhecimento.

Veja as técnicas utilizadas por antispywares

- Varredura de assinaturas: Semelhante aos antivírus, os programas antispyware podem procurar por assinaturas conhecidas de spyware.
- Monitoramento em tempo real: Muitos programas antispyware também monitoram o comportamento do sistema para detectar ações que são indicativas de spyware, como a tentativa de modificar arquivos de sistema ou coletar dados do teclado.
- Imunização: Alguns programas antispyware também têm a capacidade de "imunizar" um sistema contra certos tipos de spyware, alterando as configurações do sistema ou bloqueando sites conhecidos por distribuir spyware.

A diferença entre antivírus e antispyware pode ser confusa, pois muitos programas modernos de segurança do computador oferecem ambos os tipos de proteção. No



11225354498 - Maria Vitória Gonçalves Vieira

entanto, tradicionalmente, os programas antivírus foram projetados para detectar uma ampla gama de malware, enquanto os programas antispyware foram especificamente projetados para lidar com spyware.

## Firewall

Firewall é um sistema de segurança de rede que monitora e controla o tráfego de rede com base em regras de segurança pré-determinadas. Ele forma uma barreira entre redes confiáveis e não confiáveis, como a Internet e a sua rede interna (Intranet).




Firewalls podem ser baseados em hardware ou software:

Firewalls baseados em hardware: Também conhecidos como firewalls de rede, estes são dispositivos físicos que são conectados entre a rede de um computador e a internet. Eles são comumente usados por empresas e instituições para proteger grandes redes de computadores.

Firewalls baseados em software: Estes são programas que são instalados diretamente em um computador individual. Eles protegem esse computador específico do tráfego indesejado da Internet.

Firewalls funcionam criando regras para o tráfego de entrada e saída. Cada pacote de dados que passa pelo firewall é verificado em relação a estas regras. Se um pacote de dados não cumprir uma das regras, ele é bloqueado pelo firewall.

É importante notar que, hoje me dia, firewalls podem oferecer diversas funcionalidades diferentes, tudo no mesmo "pacote", por exemplo:

| FUNÇÕES AUXILIARES |
| --- |
| Implementar recursos de NAT (Network Address Translation); |
| Implementar DMZ (Delimitarized Zone – Zona Desmilitarizada); |
| Implementar funções de balanceamento de carga; |
| Implementar funções de antispoofing; |
| Implementar funções de autenticação de usuário; |
| Implementar funções de criptografia de comunicações (VPN – Virtual Private Network); |
| Implementar funções de alta disponibilidade; |
| Implementar filtros de URL, Spam e E-mails; |
| Implementar bloqueios de alguns tipos de Ataque de DoS (Denial of Service - Negação de Serviço); |
| Implementar bloqueios de tráfego na camada de enlace por meio do Endereço MAC; |

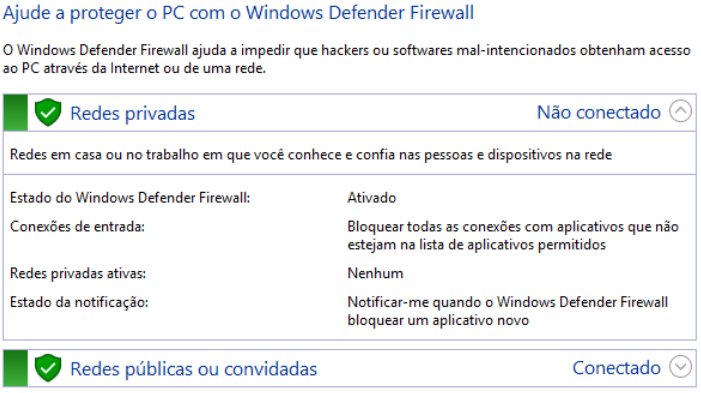
## Tipos de Firewalls

De forma geral, podemos classificar firewalls como firewall pessoal, de filtro de pacotes e de filtro de estado de sessão.

### Firewall Pessoal

Um firewall pessoal é um tipo de firewall baseado em software que é instalado diretamente em um único computador. Seu principal objetivo é proteger esse computador específico contra acessos não autorizados, tanto de tráfego de entrada quanto de saída.

O firewall pessoal monitora todas as conexões de rede do computador e permite que o usuário controle quais programas podem se comunicar através da rede. Por exemplo, um usuário pode configurar seu firewall pessoal para bloquear todo o tráfego de entrada, exceto o tráfego que é necessário para os serviços da web que o usuário quer usar, como e-mail ou navegação na web.




Um exemplo comum de firewall pessoal é o firewall do Windows que vem integrado com o sistema operacional Windows. Ele permite que os usuários controlem o tráfego de rede de e para seu computador, bloqueando ou permitindo conexões específicas com base em regras definidas pelo usuário. Outro

exemplo é o ZoneAlarm, que é um firewall pessoal de terceiros que oferece recursos avançados, como monitoramento em tempo real e proteção contra roubo de identidade.

Filtro de Pacotes

Um filtro de pacotes é o tipo mais básico de firewall corporativo. Ele opera na camada de rede do modelo OSI e verifica cada pacote de dados que passa através dele contra um conjunto de regras de segurança.

As regras podem ser baseadas em várias partes do pacote de dados, incluindo o endereço IP de origem, o endereço IP de destino, o número da porta, o protocolo (por exemplo, TCP, UDP) e assim por diante. Se um pacote corresponder a uma das regras do firewall, ele será permitido passar; caso contrário, ele será bloqueado.

Embora os filtros de pacotes sejam eficazes na prevenção de alguns tipos de ataques, eles têm várias limitações. Por exemplo, eles não podem bloquear conteúdo específico, como sites da web ou tipos de arquivo, e não podem proteger contra ataques que utilizem pacotes aparentemente legítimos para explorações.

Um exemplo de firewall que utiliza filtragem de pacotes é o iptables, que é um utilitário de firewall popular no Linux. O iptables permite que os administradores de sistemas definam regras detalhadas para o tráfego de entrada e saída, incluindo regras baseadas em endereços IP, portas e protocolos.

Filtro de Estado de Sessão

Um filtro de estado de sessão, também conhecido como firewall de inspeção de estado, é uma evolução do filtro de pacotes. Além de verificar os pacotes de dados individuais, como faz um filtro de pacotes, um filtro de estado de sessão também rastreia o estado da conexão em que os pacotes estão sendo enviados.

Em outras palavras, em vez de tratar cada pacote de dados como uma entidade separada, um filtro de estado de sessão leva em conta o contexto no qual os pacotes são enviados. Por exemplo, ele pode verificar se um pacote de entrada é uma resposta a um pedido de saída anterior.

Isso permite que os filtros de estado de sessão bloqueiem tipos de tráfego que os filtros de pacotes não podem. Por exemplo, eles podem bloquear pacotes de entrada que não são respostas a solicitações de saída, o que pode ajudar a prevenir certos tipos de ataques de falsificação de IP. Além disso, ao acompanhar o estado das conexões, eles podem detectar e bloquear tentativas de explorar vulnerabilidades de



11225354498 - Maria Vitória Gonçalves Vieira

protocolo ou tentativas de enviar grandes volumes de tráfego em uma tentativa de sobrecarregar o sistema (ataques DoS ou DDoS).

Um exemplo de firewall que utiliza filtragem de estado de sessão é o firewall Check Point. O Check Point é um firewall de nível empresarial que oferece inspeção de estado, bem como outras funcionalidades avançadas, como prevenção de intrusões e filtragem de conteúdo.

Outro exemplo seria o pfSense, que é uma distribuição de firewall gratuita e de código aberto baseada no FreeBSD. Ele utiliza o PF (Packet Filter), uma ferramenta de firewall que suporta filtragem de estado de sessão, entre outras funcionalidades.

A tabela abaixo comparando os três tipos de firewalls:

| | Firewall Pessoal | Filtro de Pacotes | Filtro de Estado de Sessão |
|---|---|---|---|
| **Definição** | **Software que é instalado diretamente em um computador individual para proteger contra acessos não autorizados.** | **Firewall que opera na camada de rede e verifica cada pacote de dados contra um conjunto de regras de segurança.** | **Evolução do filtro de pacotes que, além de verificar os pacotes de dados, também rastreia o estado da conexão.** |
| **Como funciona** | **Monitora todas as conexões de rede do computador e permite que o usuário controle quais programas podem se comunicar através da rede.** | **Verifica cada pacote de dados contra regras baseadas em várias partes do pacote de dados, como o endereço IP de origem/destino, o número da porta, o protocolo, etc.** | **Além de verificar pacotes individuais, também rastreia o estado da conexão em que os pacotes estão sendo enviados. Leva em conta o contexto no qual os pacotes são enviados.** |
| **Exemplos** | **Firewall do Windows, ZoneAlarm** | **iptables no Linux** | **Check Point, pfSense** |
| **Vantagens** | **Simples de usar e geralmente vem pré-instalado em** | **Pode bloquear tráfego com base em** | **Capaz de prevenir certos tipos de ataques** |



11225354498 - Maria Vitória Gonçalves Vieira

| | | | |
|---|---|---|---|
| | **sistemas operacionais. Bom para usuários individuais ou pequenas redes.** | **endereços IP, portas e protocolos.** | **que os filtros de pacotes não podem, como ataques de falsificação de IP e ataques DoS/DdoS.** |
| **Desvantagens** | **Não é adequado para proteger redes grandes ou complexas.** | **Não pode bloquear conteúdo específico, como sites ou tipos de arquivos.** | **Mais complexo e pode ser mais difícil de configurar corretamente.** |

## Proxy

Um servidor proxy é um intermediário que se coloca entre o seu computador (ou rede local) e a internet. Quando você faz um pedido para acessar um site ou serviço na internet, em vez de ir diretamente para o destino, o pedido é primeiro encaminhado para o servidor proxy. O proxy então faz o pedido em seu nome e retorna a resposta para você.

Proxies são usados para aumentar a segurança de redes por várias razões:

- Anonimato: Como o servidor proxy faz os pedidos em seu nome, o site ou serviço que você está acessando vê o endereço IP do servidor proxy, não o seu. Isso ajuda a proteger sua identidade.
- Filtragem de Conteúdo: Servidores proxy podem ser configurados para bloquear certos tipos de conteúdo, como sites inapropriados ou perigosos. Isso é útil em ambientes corporativos ou educacionais.
- Proteção contra ameaças online: Alguns servidores proxy incluem funcionalidades de segurança adicionais, como detecção de malware e prevenção de intrusões.
- Controle de uso da rede: Em uma organização, um servidor proxy pode ser usado para controlar o acesso à internet, permitindo ou bloqueando acesso a determinados sites ou serviços.
- Melhoria de desempenho: Proxies também podem armazenar em cache (ou seja, armazenar localmente) conteúdo da web, o que acelera o acesso a sites frequentemente visitados.



11225354498 - Maria Vitória Gonçalves Vieira

É importante notar que, embora um servidor proxy possa aumentar a segurança, ele também representa um ponto único de falha. Se o servidor proxy for comprometido, todos os dados que passam por ele podem estar em risco. Portanto, é crucial garantir que os servidores proxy sejam adequadamente protegidos e mantidos atualizados.

Finalmente, é bom lembrar que algumas bancas organizadoras utilizam o conceito de que um Firewall que atua na camada de aplicação nada mais é do que um Proxy.

Veja algumas definições de Proxy que já foram cobradas em prova:

| DEFINIÇÕES DE PROXY |
| --- |
| Servidor que visa intermediar as mensagens de nível de aplicação entre clientes internos e servidores externos, para impor uma política de segurança de uma empresa. |
| Servidor que funciona como intermediário entre um navegador da web e a Internet. |
| Servidor que permite realizar um controle de acesso a endereços da internet, bloqueando páginas através de seus endereços e/ou palavras previamente definidas. |
| Servidor que age como intermediário nas requisições entre componentes da rede e entidades externas ou internas a ela de modo a simplificar ou controlar a sua complexidade. |
| Servidor (sistema de computador ou uma aplicação) que atua como um intermediário entre os computadores de uma rede e a Internet. |

## IDS e IPS

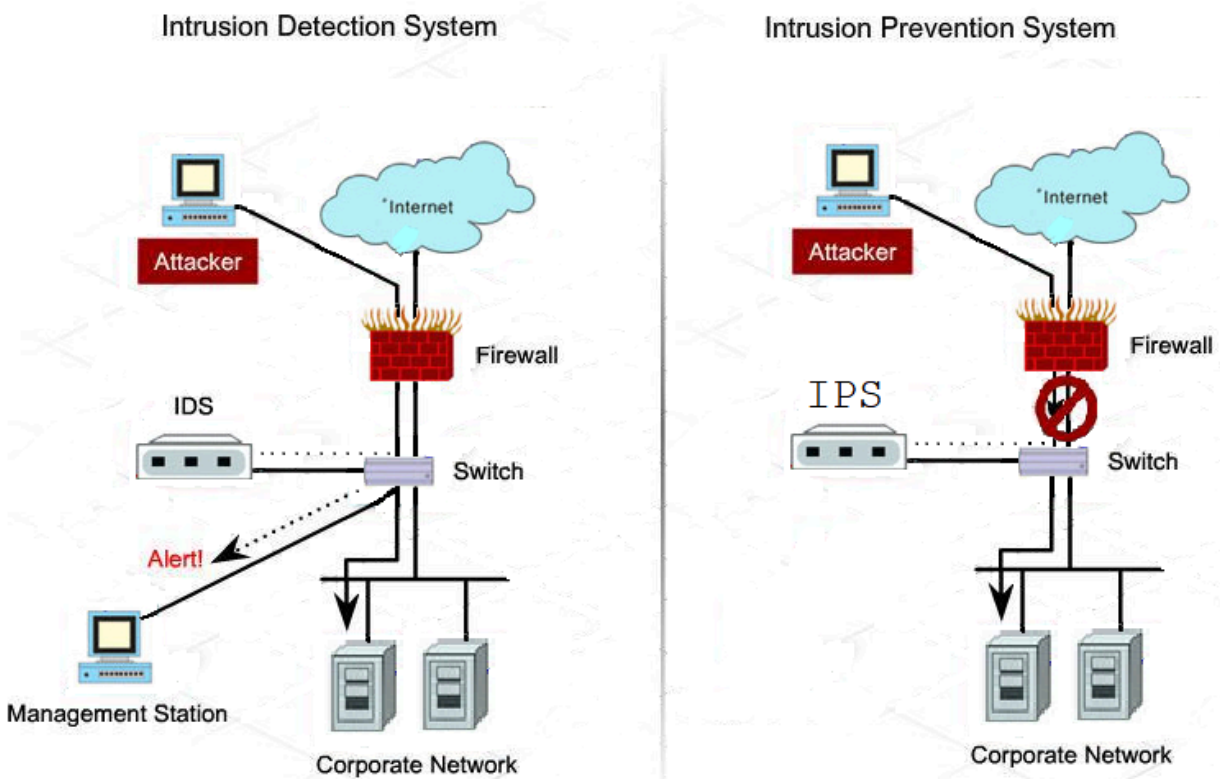
IDS e IPS são dois tipos de sistemas usados para monitorar e proteger redes contra atividades suspeitas ou mal-intencionadas. Ambos se concentram na detecção de intrusões e ataques na rede, mas diferem na maneira como respondem a essas ameaças.

IDS significa "Sistema de Detecção de Intrusões" (Intrusion Detection System, em inglês). O IDS monitora o tráfego da rede em busca de atividades suspeitas ou anômalas. Ele compara o tráfego da rede a um banco de dados de assinaturas de ataques conhecidos ou usa análise comportamental para identificar atividades que se desviam dos padrões normais. Quando uma atividade suspeita é detectada, o IDS gera um alerta e registra o evento, mas não toma nenhuma ação para parar ou mitigar a atividade. Em suma, o IDS é como um sistema de alarme que soa quando detecta atividade suspeita.



11225354498 - Maria Vitória Gonçalves Vieira

IPS significa "Sistema de Prevenção de Intrusões" (Intrusion Prevention System, em inglês). O IPS também monitora o tráfego da rede em busca de atividades suspeitas, mas ao contrário do IDS, ele é capaz de tomar medidas para bloquear ou prevenir a atividade suspeita. Quando o IPS detecta uma ameaça, ele pode bloquear o tráfego, encerrar a conexão ou redirecionar o tráfego, dependendo de como está configurado. Em outras palavras, o IPS não apenas detecta ameaças, mas também age para prevenir ataques.




A tabela a seguir resume as principais diferenças entre IPS e IDS:

| | IDS (Sistema de Detecção de Intrusões) | IPS (Sistema de Prevenção de Intrusões) |
|---|---|---|
| **Definição** | **Um sistema que monitora o tráfego de rede para identificar atividades suspeitas ou mal-intencionadas.** | **Um sistema que não apenas detecta atividades suspeitas ou mal-intencionadas, mas também toma medidas para bloquear ou prevenir essas atividades.** |
| **Função principal** | **Detectar atividades suspeitas e gerar alertas.** | **Detectar e prevenir atividades suspeitas.** |
| **Ação tomada após a detecção** | **Registra a atividade e alerta os administradores do sistema,** | **Pode bloquear o tráfego, encerrar a conexão ou** |

| | | |
|---|---|---|
| | **mas não toma nenhuma ação para parar a atividade.** | **redirecionar o tráfego, dependendo de como está configurado.** |
| **Posição na rede** | **Geralmente posicionado para monitorar o tráfego interno da rede.** | **Normalmente colocado na borda da rede para proteger contra ameaças externas.** |
| **Benefícios** | **Fornece visibilidade sobre atividades suspeitas e pode ajudar na identificação de tendências de segurança.** | **Pode agir imediatamente para prevenir ataques, reduzindo o risco de danos à rede.** |
| **Desvantagens** | **Não pode parar ou prevenir ataques. Pode haver atrasos entre a detecção de uma ameaça e a resposta a ela.** | **Pode haver falsos positivos que resultam no bloqueio de tráfego legítimo. Requer uma configuração cuidadosa para garantir que não bloqueie o tráfego legítimo.** |

## Tipos de IDS e IPS

Sistemas de detecção e prevenção de intrusões (IDS e IPS) podem ser classificados em vários tipos com base em onde são colocados na rede e como detectam atividades suspeitas ou mal-intencionadas.

IDS e IPS baseados em host (HIDS e HIPS):

- HIDS e HIPS são instalados em um host individual, como um servidor ou um endpoint.
- Eles monitoram a atividade do sistema operacional e do sistema de arquivos para detectar comportamento anormal ou suspeito.
- Exemplos podem incluir modificações inesperadas de arquivos do sistema ou tentativas de alterar configurações de segurança.

IDS e IPS baseados em rede (NIDS e NIPS):

- NIDS e NIPS são instalados em um ponto estratégico da rede para monitorar o tráfego de dados.
- Eles analisam os pacotes que passam pela rede para identificar atividades suspeitas, como tentativas de exploração de vulnerabilidades conhecidas.

IDS e IPS baseados em assinatura:



11225354498 - Maria Vitória Gonçalves Vieira

- IDS e IPS baseados em assinatura detectam ameaças comparando o tráfego de rede a um banco de dados de assinaturas de ataques conhecidos.
- Quando um padrão de tráfego corresponde a uma assinatura, o sistema gera um alerta (no caso do IDS) ou toma uma ação para bloquear o tráfego (no caso do IPS).

IDS e IPS baseados em anomalias:

- IDS e IPS baseados em anomalias usam aprendizado de máquina e estatísticas para estabelecer uma linha de base do comportamento normal da rede.
- Qualquer comportamento que se desvie significativamente dessa linha de base é considerado suspeito.

## Honeypot

Muitas vezes um IDS/IPS pode implementar uma técnica chamada de Honeypot, que é utilizada para atrair e identificar ataques cibernéticos. É um sistema ou dispositivo que aparenta ser um alvo atrativo e vulnerável aos invasores, mas na realidade, é controlado e monitorado pelos administradores de segurança.

A ideia principal de um honeypot é atrair os hackers, fornecendo um ambiente simulado ou falso que parece ser valioso em termos de informações ou recursos. Os honeypots podem simular servidores, redes, aplicativos ou outros sistemas que sejam alvos comuns de ataques. Eles são projetados para parecerem fáceis de invadir, com vulnerabilidades propositais, a fim de enganar os invasores.

Honeypots podem ser classificados em duas categorias principais: honeypots de baixa interatividade e honeypots de alta interatividade. Os honeypots de baixa interatividade são sistemas que emulam serviços ou protocolos específicos e registram as interações, sem permitir um acesso real ao ambiente interno. Já os honeypots de alta interatividade são sistemas completos, onde os invasores podem executar ações reais, mas todas as atividades são monitoradas.

Ao implantar um honeypot, uma organização pode obter mais informações sobre as táticas dos invasores e, assim, entender melhor as ameaças e melhorar suas medidas de segurança.



11225354498 - Maria Vitória Gonçalves Vieira

# EDR

EDR, ou Endpoint Detection and Response (Detecção e Resposta em Endpoint, em português), é uma solução de segurança projetada para proteger os endpoints de uma rede (ou seja, os dispositivos que se conectam à rede, como laptops, desktops e smartphones) contra ameaças cibernéticas.

EDR vai além das soluções de segurança de endpoint tradicionais, como antivírus, oferecendo recursos mais sofisticados para detecção, investigação e mitigação de ameaças.

Veja algumas das principais funcionalidades:

- Detecção e alerta de ameaças: Um sistema EDR pode monitorar continuamente a atividade do sistema em cada endpoint, procurando por comportamentos suspeitos que possam indicar uma infecção por malware ou outra ameaça cibernética. Isso inclui, por exemplo, modificações inesperadas em arquivos do sistema ou tentativas de estabelecer conexões de rede para endereços IP suspeitos.
- Análise e investigação de ameaças: Quando uma atividade suspeita é detectada, um sistema EDR pode coletar e analisar dados adicionais para ajudar os analistas de segurança a entender a natureza e a gravidade da ameaça. Abrange, por exemplo, a coleta de informações sobre processos em execução, arquivos modificados e atividades de rede.
- Resposta e mitigação de ameaças: Além de detectar e analisar ameaças, um sistema EDR também pode tomar medidas para responder a elas. Isso pode incluir, por exemplo, a quarentena de um sistema infectado para impedir a propagação do malware, a reversão de mudanças feitas por um malware ou o bloqueio de conexões de rede para endereços IP suspeitos.

## Como funciona um EDR

Um EDR funciona monitorando continuamente os endpoints em uma rede para identificar e responder a ameaças de segurança potenciais. O processo geralmente segue estes passos:

1. Coleta de Dados:

O EDR começa coletando dados de eventos de cada endpoint. Isso inclui dados sobre processos do sistema operacional, registros de chamadas de sistema, atividades de



11225354498 - Maria Vitória Gonçalves Vieira

rede, modificações em arquivos e registros, e mais. Essas informações são registradas em tempo real e enviadas para um banco de dados central para análise.

2. Análise e Detecção:

Os dados coletados são então analisados para identificar comportamentos suspeitos ou maliciosos. Isso é frequentemente feito usando técnicas de aprendizado de máquina para estabelecer uma linha de base de comportamento normal e identificar desvios significativos dessa linha de base. Os EDRs também podem usar bancos de dados de ameaças conhecidas para procurar assinaturas de malware ou técnicas de ataque conhecidas.

3. Alerta e Investigação:

Quando uma atividade suspeita ou maliciosa é identificada, o sistema EDR gera um alerta. Os analistas de segurança podem então investigar o alerta para determinar se é uma ameaça legítima. O EDR fornece ferramentas para ajudar na investigação, como a capacidade de visualizar uma linha do tempo dos eventos relacionados ou obter mais detalhes sobre processos ou arquivos suspeitos.

4. Resposta e Mitigação:

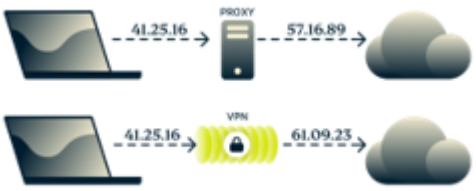
Se uma ameaça é confirmada, o sistema EDR pode tomar medidas para responder. Isso pode incluir ações como isolar um sistema infectado para evitar a propagação do malware, eliminar o processo ou arquivo malicioso, ou reverter mudanças indesejadas feitas por um malware. Além disso, os analistas de segurança podem usar as informações coletadas pelo EDR para ajudar a prevenir futuras infecções.

## VPN

VPN, ou Rede Privada Virtual (Virtual Private Network, em inglês), é uma tecnologia que cria uma conexão segura e criptografada, ou "túnel", sobre uma rede menos segura, como a internet. Ela permite que você navegue na internet de forma privada e segura, protegendo suas informações de serem vistas ou interceptadas por outros.



11225354498 - Maria Vitória Gonçalves Vieira




As VPNs são comumente usadas para:

- Privacidade: VPNs escondem seu endereço IP e localização, o que pode ajudar a proteger sua privacidade online. Todo o tráfego de internet é direcionado através do túnel criptografado, tornando difícil para terceiros rastrearem suas atividades online.
- Segurança: VPNs usam criptografia forte para proteger seus dados de serem interceptados ou lidos por pessoas não autorizadas. Isso é especialmente importante se você estiver usando uma rede Wi-Fi pública, que pode não ser segura.
- Acesso remoto a uma rede corporativa: As empresas muitas vezes usam VPNs para permitir que os funcionários acessem recursos da rede corporativa de forma segura quando estão fora do escritório.
- Contornar restrições geográficas: VPNs podem ser usadas para acessar conteúdo que pode ser geograficamente restrito, fazendo parecer que você está navegando a partir de um local diferente.
- Prevenir a limitação de velocidade: Alguns provedores de internet podem limitar a velocidade de sua conexão quando você está acessando certos tipos de conteúdo. Usar uma VPN pode ajudar a evitar isso, pois o provedor de internet não pode ver o que você está acessando.

Em termos de segurança de redes, VPNs podem ajudar de diversas formas, tais como:

Criptografia de Dados:

Uma das principais formas pelas quais as VPNs contribuem para a segurança de redes é através da criptografia de dados. Quando você se conecta à internet através de uma VPN, seus dados são criptografados antes de serem transmitidos pela rede. Isso significa que, mesmo que alguém consiga interceptar seus dados, eles não serão capazes de entender as informações sem a chave de descriptografia correta.

Anonimato:

As VPNs também fornecem anonimato, escondendo seu endereço IP real e substituindo-o pelo endereço IP do servidor VPN ao qual você está conectado. Isso pode ajudar a proteger sua identidade e atividades online de serem rastreadas.

Segurança em Redes Públicas:

VPNs são particularmente úteis quando se usa redes Wi-Fi públicas, que podem não ser seguras. Ao se conectar a uma VPN, seus dados são protegidos, mesmo que a rede Wi-Fi pública seja comprometida.

Acesso Seguro a Redes Privadas:

Uma VPN permite que usuários remotos acessem redes privadas (como a rede de uma empresa) de forma segura pela internet. Isso é crucial para empresas que têm funcionários trabalhando remotamente, pois garante que os dados transmitidos entre o usuário remoto e a rede privada permaneçam seguros.

Proteção contra Ataques de Intermediários:

Ao criar um "túnel" seguro entre o usuário e a internet, as VPNs ajudam a prevenir ataques de intermediários (como ataques man-in-the-middle), onde um invasor intercepta e potencialmente altera as comunicações entre duas partes sem o conhecimento delas.

## Tipos de VPN

Existem alguns tipos diferentes de VPN que podem ser escolhidos a depender da sua necessidade. Cada um tem suas próprias características e casos de uso. Os mais comuns incluem:

VPN de Acesso Remoto:

Este é provavelmente o tipo mais comum de VPN e é o que a maioria das pessoas pensam quando ouve o termo VPN. Ele permite que usuários individuais se conectem a uma rede privada (como a rede de uma empresa) pela internet. Isso pode ser útil para trabalhadores remotos que precisam acessar recursos da rede de sua empresa de forma segura.

VPN Site-a-Site:

Também conhecida como VPN Router-to-Router, esta é uma conexão de rede privada entre duas redes locais diferentes (LANs) pela internet. Ela é comumente usada para conectar múltiplos locais de uma empresa, permitindo que eles compartilhem recursos como se estivessem na mesma rede local. Existem dois subtipos principais de VPNs Site-a-Site: Intranet e Extranet. A VPN Intranet conecta LANs dentro de uma única



11225354498 - Maria Vitória Gonçalves Vieira

organização, enquanto a VPN Extranet permite a conexão segura entre LANs de diferentes organizações.

VPN de Camada 2 (L2TP/IPsec, PPTP):

Este tipo de VPN usa protocolos de camada 2, como o L2TP (Layer 2 Tunneling Protocol) ou PPTP (Point-to-Point Tunneling Protocol), para criar um "túnel" seguro pela internet. Essas VPNs são comumente usadas para conexões de acesso remoto.

VPN de Camada 3 (SSTP, IKEv2):

Essas VPNs, também conhecidas como VPNs SSL (Secure Sockets Layer), usam protocolos de camada 3 para criptografia e autenticação. Elas são comumente usadas para fornecer acesso seguro a aplicativos baseados na web e outros recursos online.

VPNs SSL/TLS (OpenVPN):

Este tipo de VPN utiliza os protocolos SSL (Secure Sockets Layer) ou TLS (Transport Layer Security) para criar uma conexão segura. OpenVPN é um exemplo popular de uma VPN SSL/TLS. Ele é altamente configurável e pode ser usado para ambos, VPNs de acesso remoto e site-a-site.

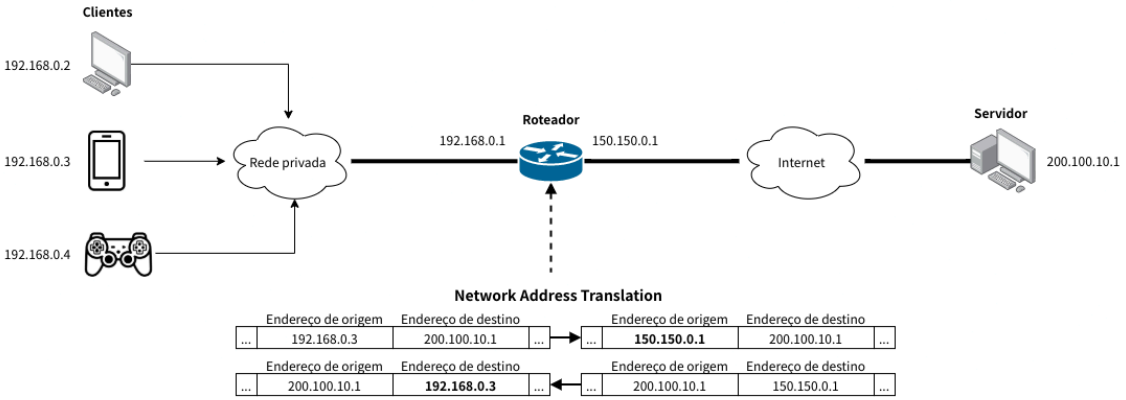
## NAT

NAT, ou Network Address Translation (Tradução de Endereços de Rede), é um processo que os roteadores usam para trocar os endereços IP de pacotes de dados à medida que passam de uma rede para outra.

Em uma rede privada, cada dispositivo tem um endereço IP único atribuído a ele. No entanto, quando esses dispositivos se conectam à internet, eles todos compartilham o mesmo endereço IP público que é atribuído pelo provedor de serviços de Internet (ISP). Isso é possível graças ao NAT.



11225354498 - Maria Vitória Gonçalves Vieira




Veja algumas vantagens fornecidas por um NAT:

- Economia de Endereços IP: Uma das principais razões para o uso do NAT é a economia de endereços IP. Como existem um número limitado de endereços IP públicos disponíveis, o NAT permite que muitos dispositivos em uma rede privada compartilhem o mesmo endereço IP público ao se conectar à internet.
- Segurança: O NAT também pode melhorar a segurança. Como os endereços IP internos são mantidos privados e os dispositivos usam o endereço IP público do roteador para se comunicar com a internet, torna-se mais difícil para os invasores direcionarem dispositivos específicos em sua rede.
- Flexibilidade: O NAT oferece flexibilidade para a administração de rede. Por exemplo, se uma empresa mudar de ISP, ela pode manter a mesma estrutura de rede interna e apenas mudar o endereço IP público fornecido pelo novo ISP.

## Tipos de NAT

Os tipos mais comuns de NAT são: Estático, Dinâmico e PAT (Port Address Translation).

NAT Estático (Static NAT):

O NAT estático é o tipo mais simples de NAT. Nele, cada endereço IP privado é mapeado para um endereço IP público específico e essa correspondência permanece constante. Isso é comumente usado para dispositivos que necessitam de um endereço IP público constante, como servidores web.

NAT Dinâmico (Dynamic NAT):

O NAT dinâmico é um pouco mais complexo. Nele, um pool de endereços IP públicos é reservado e qualquer endereço IP privado que precisa acessar a internet é mapeado para um desses endereços IP públicos disponíveis. Quando a sessão termina, o

endereço IP público é retornado ao pool para ser reutilizado. Isso é útil para redes que têm mais dispositivos do que endereços IP públicos disponíveis.

NAT de Tradução de Porta (Port Address Translation - PAT):

PAT, também conhecido como NAT Overloading, é uma forma de NAT que permite que vários dispositivos em uma rede privada compartilhem um único endereço IP público. Ele faz isso anexando um número de porta único a cada solicitação de saída. Quando a resposta chega, o roteador usa o número de porta para determinar para qual dispositivo a resposta deve ser encaminhada. PAT é o tipo mais comum de NAT e é o que a maioria dos roteadores domésticos usa.

A tabela a seguir compara os três tipos de NAT:

| | NAT Estático | NAT Dinâmico | PAT (NAT Overloading) |
|---|---|---|---|
| **Definição** | **Mapeia um endereço IP privado para um endereço IP público específico constantemente.** | **Mapeia endereços IP privados para endereços IP públicos a partir de um pool disponível.** | **Mapeia múltiplos endereços IP privados para um único endereço IP público, usando números de porta únicos.** |
| **Uso** | **Ideal para servidores web ou dispositivos que necessitam de um endereço IP público constante.** | **Ideal para redes com mais dispositivos do que endereços IP públicos disponíveis.** | **Comumente usado em roteadores domésticos, permite que muitos dispositivos compartilhem um único endereço IP público.** |



11225354498 - Maria Vitória Gonçalves Vieira

| | | | |
|---|---|---|---|
| **Vantagens** | **Simples e fácil de configurar.** | **Economiza endereços IP públicos.** | **Maximiza a economia de endereços IP públicos.** |
| **Desvantagens** | **Necessita de um endereço IP público para cada dispositivo.** | **Mais complexo de configurar e administrar do que o NAT estático.** | **Pode haver conflitos de porta se muitos dispositivos estiverem usando o mesmo tipo de serviço ao mesmo tempo.** |

## APOSTA ESTRATÉGICA

*A ideia desta seção é apresentar os pontos do conteúdo que mais possuem chances de serem cobrados em prova, considerando o histórico de questões da banca em provas de nível semelhante à nossa, bem como as inovações no conteúdo, na legislação e nos entendimentos doutrinários e jurisprudenciais*[1].

Os sistemas de detecção de intrusões (IDS) e os sistemas de prevenção de intrusões (IPS) são componentes fundamentais da segurança de redes modernas, desempenhando papéis cruciais na proteção contra ameaças cibernéticas. Um IDS monitora o tráfego de rede e os sistemas para detectar atividades suspeitas ou anormais. Utilizando uma combinação de assinaturas de ataques conhecidos e técnicas de detecção baseadas em anomalias, um IDS pode alertar os administradores de segurança sobre potenciais incidentes de segurança, permitindo-lhes investigar e responder apropriadamente. Esses sistemas são essenciais para identificar atividades maliciosas que podem não ser imediatamente evidentes, fornecendo uma camada adicional de segurança que complementa as defesas de firewall e antivírus tradicionais.

Por outro lado, um IPS é muitas vezes considerado uma extensão do IDS, não apenas detectando ameaças, mas também tomando medidas proativas para bloqueá-las antes que causem danos. O IPS atua interceptando e analisando o tráfego de rede em tempo real, e automaticamente toma ações corretivas, como bloquear o tráfego malicioso ou encerrar sessões suspeitas, para prevenir intrusões. Isso é particularmente

[1] Vale deixar claro que nem sempre será possível realizar uma aposta estratégica para um determinado assunto, considerando que às vezes não é viável identificar os pontos mais prováveis de serem cobrados a partir de critérios objetivos ou minimamente razoáveis.

útil em ambientes onde a velocidade de resposta é crítica para minimizar o impacto de ataques cibernéticos. Além disso, enquanto um IDS pode necessitar de intervenção humana para responder a alertas, um IPS fornece uma resposta automatizada, o que pode ser crucial para a eficácia da segurança em redes de alta velocidade e grande volume de dados.

## Questões Estratégicas

*Nesta seção, apresentamos e comentamos uma amostra de questões objetivas selecionadas estrategicamente: são questões com nível de dificuldade semelhante ao que você deve esperar para a sua prova e que, em conjunto, abordam os principais pontos do assunto.*

*A ideia, aqui, não é que você fixe o conteúdo por meio de uma bateria extensa de questões, mas que você faça uma boa revisão global do assunto a partir de, relativamente, poucas questões.*

1. (FGV / AGENERSA - RJ - 2023) Sobre vírus e worms no contexto de pragas virtuais, analise as afirmativas a seguir.

I. Worms não precisam se alojar em outros programas para se espalhar.

II. Vírus e worms agem basicamente enganando os usuários, por meio de e-mails e sites falsos, de forma a obter informações, senhas, dados pessoais e números de contas e cartões de crédito. III. Vírus e worms são capazes de replicarem a si mesmos.

Está correto o que se afirma em

a) I, apenas.

b) I e II, apenas.

c) I e III, apenas.

d) II e III, apenas.

e) I, II e III.

Comentários:



11225354498 - Maria Vitória Gonçalves Vieira

(I) Correto, eles exploram vulnerabilidades de rede e se replicam de forma independente; (II) Errado, isso seria phishing; (III) Correto, ambos são capazes de se replicar e criar cópias de si mesmos para se espalhar e infectar outros sistemas.

Gabarito: Letra C

2. (FGV / Senado Federal – Policial Legislativo – 2022) Sobre a natureza dos ataques Dos e DDoS em redes de computadores, assinale a afirmativa correta.

a) Enviam numerosos e-mails com links falsos, direcionados para programas e downloads maliciosos.

b) Interceptam a comunicação em locais públicos em busca de informações sobre logins/senhas, dentre outras.

c) Tentam assumir remotamente o controle de outros computadores por meio de vulnerabilidades no Firewall.

d) Tentam sobrecarregar um ou mais servidores de modo a impedir o funcionamento normal os serviços.

e) Usam a "força bruta" para descobrir, por tentativas e erro, logins/senhas para invadir contas e acessar dados sensíveis.

Comentários:

DoS/DDoS são ataques de negação de serviço, isto é, ataques que sobrecarregam recursos com o intuito de interromper atividades legítimas. Em outras palavras, tentam sobrecarregar um ou mais servidores de modo a impedir o funcionamento normal os serviços.

Gabarito: Letra D

3. (FGV / PC-MA – 2012) Um funcionário em uma viagem de negócios teve de levar em seu notebook arquivos classificados para uma reunião com clientes. Ele foi então aconselhado pelo pessoal de suporte da empresa a instalar um antivírus em sua máquina. Resistindo à orientação recebida, o funcionário argumentou que:

I. O software antivírus deixa minha máquina muito lenta.

II. Eu não preciso de um software antivírus porque eu nunca abro arquivos anexados em e-mails de pessoas que eu não conheço.



11225354498 - Maria Vitória Gonçalves Vieira

III. Tantas pessoas usam a Internet, eu sou apenas um na multidão. Ninguém vai me achar.

São motivos válidos para a não instalação de um programa antivírus:

a) somente a opção I

b) somente a opção II

c) somente a opção III

d) somente as opções I e II

e) nenhuma das opções.

Comentários:

(I) Errado, esse não é um motivo válido porque a máquina não fica muito lenta – ele consome recursos computacionais, mas não deixam a máquina muito lenta; (II) Errado, abrir anexos de e-mail de pessoas conhecidas também pode ocasionar infecções, além disso existem outras formas de contaminação por vírus; (III) Errado, a infecção por malwares pode ocorrer mesmo sem acesso à internet como, por exemplo, através de mídias removíveis.

Gabarito: Letra E

4. (FGV / BANESTES - 2018) Um ataque de negação de serviço a uma instituição foi detectado pelo sistema de proteção instalado, que colocou automaticamente regras de proteção para evitá-lo. Pode-se concluir que o sistema de proteção usado é do tipo:

a) IDS

b) IPS

c) EPP

d) DLP

e) DNSSEC

Comentários:



11225354498 - Maria Vitória Gonçalves Vieira

Note que o enunciado afirma que o ataque foi detectado pelo sistema de proteção, que colocou automaticamente regras de proteção para evitá-lo, portanto reagiu ao ataque. Dessa forma, só pode ser um IPS.

Gabarito: Letra B

5. (FGV / SEFAZ-BA – 2022) O ataque digital que tem como objetivo capturar informações sensíveis por meio de fraudes eletrônicas e que se utiliza de pretextos falsos, com o intuito de receber informações sensíveis dos usuários, e que ocorre com mais frequência por meio do envio de e-mails e páginas web falsas, denomina-se:

a) *IP spoofing*.

b) *pharming*.

c) *fakenews*.

d) *phishing*.

e) *tootkit*.

Comentários:

Esse é o típico caso de *phishing*: o atacante envia geralmente um e-mail com pretextos falsos com um link que redireciona para uma página falsa em que ele captura informações sensíveis do usuário. Lembrando que o IP Spoofing é basicamente um mascaramento do endereço IP verdadeiro; Pharming é um tipo de phishing que altera o endereço de uma página no servidor DNS; fakenews é um tipo de hoax; e toolkit não tem nenhum significado dentro desse contexto.

Gabarito: Letra D

## QUESTIONÁRIO DE REVISÃO E APERFEIÇOAMENTO

*A ideia do questionário é elevar o nível da sua compreensão no assunto e, ao mesmo tempo, proporcionar uma outra forma de revisão de pontos importantes do conteúdo, a partir de perguntas que exigem respostas subjetivas.*



11225354498 - Maria Vitória Gonçalves Vieira

*São questões um pouco mais desafiadoras, porque a redação de seu enunciado não ajuda na sua resolução, como ocorre nas clássicas questões objetivas.*

*O objetivo é que você realize uma auto explicação mental de alguns pontos do conteúdo, para consolidar melhor o que aprendeu ;)*

*Além disso, as questões objetivas, em regra, abordam pontos isolados de um dado assunto. Assim, ao resolver várias questões objetivas, o candidato acaba memorizando pontos isolados do conteúdo, mas muitas vezes acaba não entendendo como esses pontos se conectam.*

*Assim, no questionário, buscaremos trazer também situações que ajudem você a conectar melhor os diversos pontos do conteúdo, na medida do possível.*

*É importante frisar que não estamos adentrando em um nível de profundidade maior que o exigido na sua prova, mas apenas permitindo que você compreenda melhor o assunto de modo a facilitar a resolução de questões objetivas típicas de concursos, ok?*

*Nosso compromisso é proporcionar a você uma revisão de alto nível!*

*Vamos ao nosso questionário:*

## Perguntas

1. O que é a segurança de redes e por que é importante?
2. Como os antivírus da primeira geração detectam ameaças?
3. O que distingue o firewall de filtragem de pacotes do firewall de filtragem de estado de sessão?
4. O que é um proxy e como ele contribui para a segurança de redes?
5. Qual é a diferença entre um IDS e um IPS?
6. Como o EDR contribui para a segurança do endpoint?
7. Como uma VPN contribui para a segurança de redes?
8. O que é NAT e como ele contribui para a segurança de redes?
9. Quais são as diferenças entre NAT estático, NAT dinâmico e PAT?
10. O que é um ataque de phishing e como ele pode ser prevenido?
11. O que é um ataque DoS?
12. Como um ataque de força bruta funciona?
13. O que é um honeypot e como ele é usado na segurança de redes?
14. Qual é a diferença entre malware, vírus, worm e trojan?

15. O que são antispam e antispyware e qual é o propósito deles?
16. O que é a detecção baseada em heurística?
17. O que são firewalls pessoais?
18. Quais são os principais tipos de VPN?
19. O que é um ataque de interceptação e espionagem?
20. O que é ransomware e como ele pode ser mitigado?

## Perguntas e Respostas

1. O que é a segurança de redes e por que é importante?
   Resposta: A segurança de redes é a prática de prevenir e proteger contra acessos não autorizados a redes de computadores. É importante para garantir a integridade, confidencialidade e disponibilidade dos dados.
2. Como os antivírus da primeira geração detectam ameaças?
   Resposta: Antivírus de primeira geração detectam ameaças através da identificação de assinaturas de vírus conhecidas em arquivos.
3. O que distingue o firewall de filtragem de pacotes do firewall de filtragem de estado de sessão?
   Resposta: O firewall de filtragem de pacotes examina pacotes isoladamente, enquanto o firewall de filtragem de estado de sessão examina o estado, a porta e o protocolo da conexão.
4. O que é um proxy e como ele contribui para a segurança de redes?
   Resposta: Um proxy é um intermediário que processa solicitações de clientes em nome de outros servidores. Ele pode melhorar a segurança de redes ao ocultar o endereço IP do cliente, limitar o acesso a sites específicos e detectar malware.
5. Qual é a diferença entre um IDS e um IPS?
   Resposta: Um IDS é um sistema de detecção de intrusões que apenas detecta e alerta sobre possíveis intrusões, enquanto um IPS também é capaz de prevenir a intrusão ao bloquear o tráfego.
6. Como o EDR contribui para a segurança do endpoint?
   Resposta: O EDR coleta e analisa dados de eventos de endpoints, permitindo a detecção de ameaças, a investigação de incidentes e a resposta apropriada. Ele permite que as organizações respondam rapidamente a incidentes e ameaças emergentes.
7. Como uma VPN contribui para a segurança de redes?
   Resposta: Uma VPN cria uma conexão segura e criptografada para transmitir dados por redes públicas ou inseguras, protegendo a privacidade e os dados do usuário.



11225354498 - Maria Vitória Gonçalves Vieira

8. O que é NAT e como ele contribui para a segurança de redes?
   Resposta: NAT é um processo que mapeia endereços IP privados para endereços IP públicos. Ele pode aumentar a segurança ao ocultar endereços IP internos da internet.
9. Quais são as diferenças entre NAT estático, NAT dinâmico e PAT?
   Resposta: NAT estático mapeia um endereço IP privado para um endereço IP público específico. NAT dinâmico escolhe um endereço IP público de um pool de endereços disponíveis. PAT (também conhecido como NAT overloading) mapeia múltiplos endereços IP privados para um único endereço IP público, usando diferentes portas.
10. O que é um ataque de phishing e como ele pode ser prevenido?
    Resposta: Phishing é um tipo de ataque cibernético que envolve o envio de emails falsificados que parecem vir de fontes legítimas para induzir indivíduos a revelar informações pessoais. A prevenção de phishing envolve educação do usuário, uso de filtros de spam e software antiphishing.
11. O que é um ataque DoS?
    Resposta: Um ataque DoS (Denial of Service) é um ataque cibernético que tem como objetivo tornar um serviço ou recurso indisponível para os usuários, normalmente inundando a rede ou servidor com tráfego.
12. Como um ataque de força bruta funciona?
    Resposta: Um ataque de força bruta é um método de tentativa e erro usado para descobrir informações como senhas ou códigos PIN. O atacante tenta todas as combinações possíveis até encontrar a correta.
13. O que é um honeypot e como ele é usado na segurança de redes?
    Resposta: Um honeypot é um recurso de rede criado para atrair e distrair invasores, permitindo que os sistemas de segurança identifiquem e estudem as atividades do invasor. Ele é usado para aprender sobre métodos de ataque e monitorar atividades maliciosas.
14. Qual é a diferença entre malware, vírus, worm e trojan?
    Resposta: Malware é um termo genérico para software malicioso. Vírus é um tipo de malware que se replica ao infectar outros programas. Worm é um malware que se espalha automaticamente sem interação humana. Trojan é um malware que se disfarça como um programa legítimo.
15. O que são antispam e antispyware e qual é o propósito deles?
    Resposta: Antispam é um software ou hardware que bloqueia e filtra o spam, mensagens indesejadas ou maliciosas. Antispyware é um software que detecta, previne e remove spyware, um tipo de malware que coleta informações sobre um usuário sem o seu conhecimento.
16. O que é a detecção baseada em heurística?
    Resposta: A detecção baseada em heurística é uma estratégia usada por muitos



11225354498 - Maria Vitória Gonçalves Vieira

programas antivírus para identificar novos ou modificados tipos de malware, mesmo sem terem sido previamente identificados ou catalogados.

17. O que são firewalls pessoais?
    Resposta: Firewalls pessoais são softwares projetados para prevenir acesso não autorizado a ou de um computador pessoal. Eles são uma camada importante de defesa contra muitas formas de malware.
18. Quais são os principais tipos de VPN?
    Resposta: Os principais tipos de VPN são VPNs de acesso remoto, VPNs de site a site, e VPNs baseadas em navegador.
19. O que é um ataque de interceptação e espionagem?
    Resposta: Um ataque de interceptação e espionagem é um tipo de ataque onde a comunicação entre duas entidades é intencionalmente interceptada e potencialmente alterada.
20. O que é ransomware e como ele pode ser mitigado?
    Resposta: Ransomware é um tipo de malware que criptografa os dados do usuário e exige um resgate para restaurar o acesso aos dados. A mitigação do ransomware pode incluir práticas como backup regular de dados, educação dos usuários para evitar e-mails suspeitos, e a manutenção de software e sistemas operacionais atualizados.

## Lista de Questões Estratégicas

1. (FGV / AGENERSA - RJ - 2023) Sobre vírus e worms no contexto de pragas virtuais, analise as afirmativas a seguir.

   I. Worms não precisam se alojar em outros programas para se espalhar.

   II. Vírus e worms agem basicamente enganando os usuários, por meio de e-mails e sites falsos, de forma a obter informações, senhas, dados pessoais e números de contas e cartões de crédito. III. Vírus e worms são capazes de replicarem a si mesmos.

   Está correto o que se afirma em

   a) I, apenas.

   b) I e II, apenas.

   c) I e III, apenas.



11225354498 - Maria Vitória Gonçalves Vieira

d) II e III, apenas.

e) I, II e III.

2. (FGV / Senado Federal – Policial Legislativo – 2022) Sobre a natureza dos ataques Dos e DDoS em redes de computadores, assinale a afirmativa correta.

a) Enviam numerosos e-mails com links falsos, direcionados para programas e downloads maliciosos.

b) Interceptam a comunicação em locais públicos em busca de informações sobre logins/senhas, dentre outras.

c) Tentam assumir remotamente o controle de outros computadores por meio de vulnerabilidades no Firewall.

d) Tentam sobrecarregar um ou mais servidores de modo a impedir o funcionamento normal os serviços.

e) Usam a "força bruta" para descobrir, por tentativas e erro, logins/senhas para invadir contas e acessar dados sensíveis.

3. (FGV / PC-MA – 2012) Um funcionário em uma viagem de negócios teve de levar em seu notebook arquivos classificados para uma reunião com clientes. Ele foi então aconselhado pelo pessoal de suporte da empresa a instalar um antivírus em sua máquina. Resistindo à orientação recebida, o funcionário argumentou que:

I. O software antivírus deixa minha máquina muito lenta.

II. Eu não preciso de um software antivírus porque eu nunca abro arquivos anexados em e-mails de pessoas que eu não conheço.

III. Tantas pessoas usam a Internet, eu sou apenas um na multidão. Ninguém vai me achar.

São motivos válidos para a não instalação de um programa antivírus:

a) somente a opção I

b) somente a opção II

c) somente a opção III



11225354498 - Maria Vitória Gonçalves Vieira

d) somente as opções I e II

e) nenhuma das opções.

4. (FGV / BANESTES - 2018) Um ataque de negação de serviço a uma instituição foi detectado pelo sistema de proteção instalado, que colocou automaticamente regras de proteção para evitá-lo. Pode-se concluir que o sistema de proteção usado é do tipo:

a) IDS

b) IPS

c) EPP

d) DLP

e) DNSSEC

5. (FGV / SEFAZ-BA – 2022) O ataque digital que tem como objetivo capturar informações sensíveis por meio de fraudes eletrônicas e que se utiliza de pretextos falsos, com o intuito de receber informações sensíveis dos usuários, e que ocorre com mais frequência por meio do envio de e-mails e páginas web falsas, denomina-se:

a) *IP spoofing*.

b) *pharming*.

c) *fakenews*.

d) *phishing*.

e) *tootkit*.

## Gabaritos

1. C
2. D
3. E
4. B



11225354498 - Maria Vitória Gonçalves Vieira

5. D



11225354498 - Maria Vitória Gonçalves Vieira

# ESSA LEI TODO MUNDO CONHECE:
# PIRATARIA É CRIME.

**Mas é sempre bom revisar o porquê e como você pode ser prejudicado com essa prática.**

1. 

Professor investe seu tempo para elaborar os cursos e o site os coloca à venda.

2. 

Pirata divulga ilicitamente (grupos de rateio), utilizando-se do anonimato, nomes falsos ou laranjas (geralmente o pirata se anuncia como formador de "grupos solidários" de rateio que não visam lucro).

3. 

Pirata cria alunos fake praticando falsidade ideológica, comprando cursos do site em nome de pessoas aleatórias (usando nome, CPF, endereço e telefone de terceiros sem autorização).

4. 

Pirata compra, muitas vezes, clonando cartões de crédito (por vezes o sistema anti-fraude não consegue identificar o golpe a tempo).

5. 

Pirata fere os Termos de Uso, adultera as aulas e retira a identificação dos arquivos PDF (justamente porque a atividade é ilegal e ele não quer que seus fakes sejam identificados).

6. 

Pirata revende as aulas protegidas por direitos autorais, praticando concorrência desleal e em flagrante desrespeito à Lei de Direitos Autorais (Lei 9.610/98).

7. 

Concurseiro(a) desinformado participa de rateio, achando que nada disso está acontecendo e esperando se tornar servidor público para exigir o cumprimento das leis.

8. 

O professor que elaborou o curso não ganha nada, o site não recebe nada, e a pessoa que praticou todos os ilícitos anteriores (pirata) fica com o lucro.



**Deixando de lado esse mar de sujeira, aproveitamos para agradecer a todos que adquirem os cursos honestamente e permitem que o site continue existindo.**